

AI Audit Report

Tài liệu này ghi lại đầy đủ prompt và AI output tương ứng từ ba cuộc hội thoại Codex được tham chiếu. Mỗi prompt của người dùng được ghi thành một entry riêng theo đúng thứ tự thời gian trong từng cuộc hội thoại.

Entry #1

AI Audit Entry

Tool: **Codex** (GPT-5)

Date: **20/08/2026 22:37** — **Asia/Ho_Chi_Minh**

User Prompt:

sử dụng ai-first-api-testing thực hiện:

- Pool B
- FR-11 – Order History View
- Endpoint thuộc phạm vi FR-11:
 - GET /api/orders/my-orders
 - GET /api/orders/:id

NGUYÊN TẮC PHẠM VI

Chỉ tập trung vào FR-11.

Không phân tích, mô tả, tạo test, hoặc mở rộng sang bất kỳ FR hay endpoint nào không thuộc FR-11.

Chỉ được đọc các tài liệu khác để làm rõ contract, security rule, dependency hoặc spec gap trực tiếp liên quan đến FR-11.

Không trình bày tổng quan các Pool khác hoặc các FR khác.

TÀI LIỆU CẦN DÙNG

Đọc và tuân thủ các tài liệu liên quan trực tiếp:

- SKILL.md
- references/phase-playbook.md
- references/api-selection-contract.md
- references/api-testing-runbook.md
- references/assignment-requirements.md
- src/eshop-sut/api_specification.md
- src/eshop-sut/README.md

Chỉ đọc source code nếu cần xác minh một khoảng trống hoặc mâu thuẫn trực tiếp của FR-11.

PHẠM VI THỰC THI

Chỉ thực hiện:

PHASE A – CHỌN PHẠM VI / TRÍCH XUẤT CONTRACT CHO FR-11

Không được:

- sinh bộ test case;
- audit test case;
- thêm human-added cases;
- tạo Postman executable tests;
- chạy Newman;
- phân tích bug;
- làm CI/CD;
- làm report tổng hợp;
- chuyển sang phase tiếp theo.

Sau khi hoàn tất Phase A phải DỪNG.

NHIỆM VỤ

1. Xác minh chính xác scope của FR-11:
 - GET /api/orders/my-orders
 - GET /api/orders/:id
2. Trích xuất contract chỉ cho FR-11:
 - authentication requirement;
 - authorization requirement;
 - ownership rule;
 - path/header inputs;
 - preconditions;
 - data dependencies;
 - expected behavior có nguồn;
 - response/schema chỉ khi được tài liệu định nghĩa;
 - security requirements áp dụng trực tiếp;
 - spec gaps.
3. Đặc biệt làm rõ ba tình huống:
 - user xem danh sách order của chính mình;
 - user xem chi tiết order của chính mình;
 - user thử xem order không thuộc về mình.
4. Xác định các input/partition cần dùng cho Phase B sau này:
 - valid order id;
 - invalid/malformed id nếu phù hợp;
 - nonexistent id;
 - owned order;
 - foreign-owned order;
 - user có nhiều order;
 - user không có order.
5. Xác định các security concern trực tiếp của FR-11:
 - missing/invalid authentication;
 - authorization;
 - ownership;

- IDOR.

Không ép các security category không liên quan.

6. Không tự bịa:

- status code;
- error body;
- exact response schema;
- ownership behavior;
- validation rule.

Nếu thiếu oracle, ghi rõ:

INCOMPLETE / SPEC GAP

7. Xác định Student ID theo rule của skill/repository nhưng không gửi request.

8. Chỉ tạo/cập nhật artifact phục vụ Phase A của FR-11.

9. Ghi AI Audit cho interaction này theo skill.

OUTPUT CUỐI

Chỉ báo cáo các mục sau:

FR-11 Scope

Contract

Authentication / Authorization / Ownership

Inputs / Partitions

Applicable Security

Spec Gaps

Data Dependencies

Artifact Paths

Status

Dừng:

PHASE A: COMPLETE

HUMAN REVIEW: PENDING

NEXT ALLOWED PHASE: B – AI GENERATION

EXECUTION: NOT EXECUTED

Sau đó DỪNG.

Không được tự động thực hiện Phase B.

AI Output:

FR-11 Scope

Đã xác minh Pool B / FR-11 chỉ gồm ``GET /api/orders/my-orders`` và ``GET /api/orders/:id``. Student ID là ``23127464``; chưa gửi request. Việc xác nhận không trùng lựa chọn với thành viên khác còn chờ con người vì repository không có danh sách phân công nhóm.

Contract

``GET /api/orders/my-orders`` nhận JWT qua ``Authorization: Bearer <token>``, không có path/query/body được công bố, và phải chỉ trả dữ liệu order của chính user. ``GET /api/orders/:id`` nhận JWT cùng path ``id``; user chỉ được xem detail của order mình sở hữu. Với foreign-owned order, contract yêu cầu không tiết lộ dữ liệu, nhưng cách từ chối chính xác là ``INCOMPLETE / SPEC GAP``. Tài liệu không định nghĩa status code hay exact response schema.

Authentication / Authorization / Ownership

Cả hai endpoint theo tài liệu đều yêu cầu JWT hợp lệ. Đây là quyền truy cập theo identity/ownership, không có yêu cầu role admin. Source cho thấy route danh sách có middleware JWT và lọc ``user_id = req.user.id``; route detail hiện không có middleware và chỉ lọc theo ``id``, là mâu thuẫn contract/candidate IDOR từ kiểm tra tĩnh, chưa phải kết luận bug runtime.

Inputs / Partitions

Đã ghi các partition dành cho Phase B: valid owned ID, valid foreign-owned ID, well-formed nonexistent ID, malformed ID chỉ khi grammar được làm rõ, user có nhiều order, user không có order, cùng valid/missing/invalid/expired JWT. ``X-Student-Id: 23127464`` phải có khi thực thi sau này.

Applicable Security

Áp dụng trực tiếp: SEC-02 (JWT hợp lệ), authorization/ownership, IDOR trên ``:id``, và SEC-05 cho truy vấn tham số hóa. Không ép các SEC không liên quan.

Spec Gaps

``INCOMPLETE / SPEC GAP``: status/error body; exact list/detail schema; empty-history representation; ordering/pagination; ID grammar/validation; nonexistent-ID behavior; foreign-order rejection; admin behavior trên user-scoped endpoints; data-store error behavior. Source detail route còn mâu thuẫn yêu cầu authentication/ownership.

Data Dependencies

Cần User A có JWT và nhiều owned orders, User B có JWT và foreign order, User C có

```
JWT nhưng không có order, mapping ID-owner ổn định, một nonexistent ID, dữ liệu JWT âm tính có kiểm soát và cơ chế fixture/reset được phê duyệt. Source hiện không seed order.

### Artifact Paths

- `reports/api-testing/fr-11-phase-a-contract.md`
- `reports/ai-audit-report.md` – Entry #27

### Status

PHASE A: COMPLETE
HUMAN REVIEW: PENDING
NEXT ALLOWED PHASE: B – AI GENERATION
EXECUTION: NOT EXECUTED
```

Đánh giá/chỉnh sửa của con người:

```
PENDING
```

Entry #2

AI Audit Entry

Tool: Codex (GPT-5)

Date: 20/08/2026 22:55 – Asia/Ho_Chi_Minh

User Prompt:

```
approved, continue phase B
```

AI Output:

```
### Phase A Approval

Đã ghi nhận Phase A được phê duyệt ngày 2026-08-20 và mở gate Phase B cho FR-11. Việc không trùng lựa chọn với thành viên khác vẫn cần xác nhận riêng vì repository không có danh sách phân công nhóm.

### Phase B Result

Đã sinh 70 ca `AI-SINH`: 35 ca cho `GET /api/orders/my-orders` và 35 ca cho `GET /api/orders/:id`. Có 70 ID duy nhất, không trùng; toàn bộ giữ `Đánh giá con người: PENDING` và `Tự động hóa: NOT CREATED`.

### Coverage
```

Bao phủ JWT hợp lệ/thiếu/rỗng/sai định dạng/bị sửa/hết hạn; user có 0/1/nhiều order; owned, foreign-owned, nonexistent và malformed ID; identity isolation; authorization, ownership, IDOR, SEC-02 và SEC-05; cùng các semantic field có nguồn của FR-11.

Preserved Spec Gaps

Không tự đặt status code, error body, exact schema, ID grammar, empty-list representation hoặc foreign-order rejection. Các oracle chưa đủ nguồn đều ghi `INCOMPLETE / SPEC GAP`; source implementation không được dùng thay expected contract.

Artifact Paths

- `tests/api-testing/test-cases/fr-11-ai-generated-phase-b.md`
- `reports/api-testing/fr-11-phase-b-generation.md`
- `reports/api-testing/fr-11-phase-a-contract.md`
- `reports/ai-audit-report.md` – Entry #2

Kết quả AI đầy đủ nằm tại file test case, SHA-256 `ABB5FE9F7D6148C1F1743AC850001B7FF7401CBA454695383120414895E4667`, và được truy vết bằng chuỗi prompt trong báo cáo Phase B.

Status

PHASE B: COMPLETE
HUMAN REVIEW: PENDING
NEXT ALLOWED PHASE: C – HUMAN AUDIT AND EXTENSION
EXECUTION: NOT EXECUTED

Đánh giá/chỉnh sửa của con người:

PENDING

Entry #3

AI Audit Entry

Tool: **Codex (GPT-5)**

Date: **20/08/2026 23:15 – Asia/Ho_Chi_Minh**

User Prompt:

approved, continue

AI Output:

Phase B Approval

Đã ghi nhận Phase B được phê duyệt ngày 2026-08-20 và mở gate Phase C cho riêng FR-11. Bản AI gốc gồm 70 ca được giữ nguyên để bảo toàn dấu vết.

Phase C Progress

Đã tạo pre-audit worksheet cho đủ 70/70 ca. Đề xuất AI gồm 33 `VALID`, 2 `INVALID` và 35 `INCOMPLETE`; đây không phải kết luận audit của con người. Cả 70 cột quyết định con người vẫn là `PENDING`.

Human Review Required

Con người cần quyết định độc lập `VALID/INVALID/INCOMPLETE`, ghi lý do và chỉnh sửa cuối cùng cho từng ca. Worksheet cũng có 10 slot trống để con người tự bổ sung tối thiểu 5 ca cho mỗi endpoint; chưa có slot nào được tính là `CON-NGUOI-BO-SUNG`.

Artifact Paths

- `tests/api-testing/test-cases/fr-11-phase-c-human-review-workbook.md`
- `tests/api-testing/test-cases/fr-11-ai-generated-phase-b.md` – bản AI gốc, không ghi đề
- `reports/api-testing/fr-11-phase-b-generation.md` – Phase B đã approved
- `reports/ai-audit-report.md` – Entry #3

SHA-256 worksheet:

`9FB90DC81435A4E8F314ACDF9831819F30A63F299E84362D4BAC0CB3ACD338AE`.

Status

PHASE C: IN PROGRESS
AI PRE-AUDIT: COMPLETE
HUMAN CASE-BY-CASE AUDIT: PENDING
HUMAN-ADDED CASES: PENDING
NEXT PHASE GATE: D – LOCKED
EXECUTION: NOT EXECUTED

Đánh giá/chỉnh sửa của con người:

PENDING

Entry #4

AI Audit Entry

Tool: Codex (GPT-5)

Date: 20/08/2026 23:29 – Asia/Ho_Chi_Minh

User Prompt:

bổ sung các nội endpoint tôi cảm thấy thiếu vào

`GET /api/orders/my-orders` – 5 ca:

1. ****FR11-MYO-H01**** – Gửi `POST /api/orders/my-orders` với JWT hợp lệ → server phải reject, không trả order. Nguồn: API spec §4 chỉ công bố GET. Lý do AI bỏ sót: AI không test method mismatch.
2. ****FR11-MYO-H02**** – User A checkout tạo order mới → gọi ngay `GET /api/orders/my-orders` → order vừa tạo phải xuất hiện, status=pending. Nguồn: FR-08 + FR-11 + FR-10. Lý do AI bỏ sót: AI dùng fixture tĩnh, không test cross-feature flow checkout→lịch sử.
3. ****FR11-MYO-H03**** – Gọi `GET /api/orders/my-orders` khi DB gặp sự cố → server trả error 5xx, không crash, không lộ data. Nguồn: Phase A spec gap "xử lý lỗi kho dữ liệu"; server.js:315 không handle err. Lý do AI bỏ sót: AI không test error handling path.
4. ****FR11-MYO-H04**** – Gửi `HEAD /api/orders/my-orders` với JWT hợp lệ → trả header giống GET nhưng không có body chứa order data. Nguồn: RFC 7231 §4.3.2. Lý do AI bỏ sót: AI không test HTTP method chuẩn khác ngoài GET.
5. ****FR11-MYO-H05**** – Admin xóa User A (FR-19) → dùng token cũ của User A gọi `GET /api/orders/my-orders` → không được trả order data. Nguồn: FR-19 + FR-11 + SEC-02. Lý do AI bỏ sót: AI có MYO-032 nhưng mô tả trừu tượng, không cụ thể hóa scenario user bị xóa qua FR-19 mà JWT chưa hết hạn.

`GET /api/orders/:id` – 5 ca:

1. ****FR11-DET-H01**** – Gửi `DELETE /api/orders/:id` với JWT hợp lệ và owned ID → server reject, order không bị xóa. Nguồn: API spec chỉ công bố GET. Lý do AI bỏ sót: AI không test method mismatch.
2. ****FR11-DET-H02**** – Gọi `GET /api/orders/:id` với owned order, kiểm tra response chứa đủ cả 4 trường FR-11 đồng thời: mã đơn (id), ngày đặt (created_at), tổng tiền (total_amount), trạng thái (status). Nguồn: FR-11 "Hiển thị: Mã đơn, Ngày đặt, Tổng tiền, Trạng thái hiện tại". Lý do AI bỏ sót: AI tách thành 4 ca riêng (DET-004→007), thiếu combined assertion.
3. ****FR11-DET-H03**** – User A hủy order A1 → gọi `GET /api/orders/A1` → order vẫn hiển thị được, status=canceled. Nguồn: FR-10 (canceled là final state) + FR-11. Lý do AI bỏ sót: AI không test trạng thái order sau chuyển đổi, cross-feature FR-10→FR-11.
4. ****FR11-DET-H04**** – Gửi `GET /api/orders/..%2Fadmin%2Forders` (path traversal) với JWT hợp lệ → không được truy cập admin route, không trả danh sách tất cả orders. Nguồn: FR-11 + FR-12 + SEC-03. Lý do AI bỏ sót: AI test SQL injection (DET-025) nhưng bỏ qua path traversal.
5. ****FR11-DET-H05**** – Gọi `GET /api/orders/:id` với cùng owned order A1 hai lần liên tiếp cùng token → cả 2 response phải giống nhau, không side effect. Nguồn:

RFC 7231 §4.2.2 (GET idempotent) + FR-11. Lý do AI bỏ sót: AI test concurrent khác owner nhưng không test idempotency cùng user.

AI Output:

Human-Added Cases

Đã ghi đủ 10 ca do người dùng cung cấp với nguồn gốc `CON-NGUOI-BO-SUNG`: 5 ca `FR11-MYO-H01`-`H05` và 5 ca `FR11-DET-H01`-`H05`. Mỗi ca giữ nguồn yêu cầu, lý do AI bỏ sót và xác nhận nguồn gốc con người.

Oracle Corrections

`MYO-H04` được chỉnh theo [RFC 7231 §4.3.2](https://www.rfc-editor.org/rfc/rfc7231.html#section-4.3.2): HEAD không có message body; header chỉ `SHOULD` tương đương GET và payload header có thể bị lược bỏ. `DET-H05` được chỉnh theo [RFC 7231 §4.2.2](https://www.rfc-editor.org/rfc/rfc7231.html#section-4.2.2): idempotency áp dụng cho intended effect trên server, không bắt buộc hai response giống byte-for-byte.

Pending Eligibility

`MYO-H03` thiếu nguồn cho exact `5xx`; spec gap và source thiếu error handler không phải expected oracle. `MYO-H05` trùng semantic với `MYO-032`; `DET-H02` gộp `DET-004`-`DET-007` và dùng tên trường chưa được phê duyệt làm exact schema. Các ca vẫn được lưu nhưng cần human resolution trước khi tính đủ "AI bỏ sót".

Artifact Path

- `tests/api-testing/test-cases/fr-11-phase-c-human-review-workbook.md`
- `reports/ai-audit-report.md` – Entry #4

SHA-256 worksheet:

`07C3F8296D82A93F6757B56816FE40BDAAFD8CFA71900A620AC55A2A532F96B4`.

Status

PHASE C: IN PROGRESS
 HUMAN-ADDED CASES: 10 PROVIDED
 COUNT ELIGIBILITY: PENDING
 HUMAN CASE-BY-CASE AUDIT: PENDING
 NEXT PHASE GATE: D – LOCKED
 EXECUTION: NOT EXECUTED

Đánh giá/chỉnh sửa của con người:

PENDING

Entry #5

AI Audit Entry

Tool: **Codex (GPT-5)**

Date: **20/08/2026 23:48 – Asia/Ho_Chi_Minh**

User Prompt:

****FR11-MYO-H05**** Gọi `GET /api/orders/my-orders` với `Accept: text/xml` hoặc `Accept: application/xml`. Server phải trả JSON (hoặc 406 Not Acceptable), không được trả order data dưới format không mong đợi. Nguồn: API chỉ công bố JSON response. Lý do AI bỏ sót: AI không test content negotiation.

****FR11-DET-H02**** Gọi `PUT /api/orders/:id` với JWT hợp lệ, owned ID, body `{"status": "delivered"}`. Server phải reject – user không được tự chuyển trạng thái qua endpoint detail. Order không bị thay đổi. Nguồn: FR-10 (chỉ admin chuyển trạng thái) + API spec chỉ công bố GET. Lý do AI bỏ sót: AI không test method mismatch trên endpoint detail cho phương thức PUT.

Điền cột "Kết luận con người", "Lý do của con người" và "Chỉnh sửa cuối cùng" cho 70 ca trong file tests/api-testing/test-cases/fr-11-phase-c-human-review-workbook.md

theo hướng dẫn sau. Không sửa các cột khác.

Quy tắc gán nhãn:

- VALID: ca có đầu vào, bước, expected result đều có căn cứ từ FR-11/SEC-02/API spec và thực thi được. Chỉnh sửa = "N/A".
- INVALID: ca trùng lặp hoặc ngoài phạm vi. Ghi lý do cụ thể.
- INCOMPLETE: ca có ý nghĩa nhưng thiếu oracle (status code, schema, field name). Ghi rõ phần nào thiếu.

Gán nhãn cụ thể:

- VALID cho: MYO-004 đến MYO-008, MYO-014 đến MYO-028, MYO-030, DET-008, DET-011, DET-012, DET-025 đến DET-033.
- INVALID cho: MYO-034 (lý do: không phải test FR-11, là precondition chung), DET-013 (lý do: trùng mục tiêu DET-009).
- INCOMPLETE cho tất cả ca còn lại. Ghi phần thiếu dựa trên cột "Lý do/đề xuất chỉnh sửa của AI".

Cập nhật thống kê cuối mỗi bảng và checklist gate Phase C.

AI Output:

Human-Case Replacements

Đã thay `FR11-MYO-H05` bằng ca content negotiation và `FR11-DET-H02` bằng ca method mismatch `PUT`. Hai ca hiện là coverage khác biệt, nguồn gốc `CON-NGUOI-BO-SUNG`; không tạo request thực thi.

Human Audit Results

```
Đã điền đúng ba cột human audit cho 70/70 ca, không sửa các cột AI khác. Kết quả
`GET /api/orders/my-orders`: 21 `VALID`, 1 `INVALID`, 13 `INCOMPLETE`. Kết quả
`GET /api/orders/:id`: 12 `VALID`, 1 `INVALID`, 22 `INCOMPLETE`. Tổng cộng: 33
`VALID`, 2 `INVALID`, 35 `INCOMPLETE`; không còn quyết định `PENDING`.

### Phase C Gate

Đã hoàn tất audit từng ca, lý do/chỉnh sửa cho `INVALID` và `INCOMPLETE`, cùng 5
ca human-added khác biệt cho mỗi endpoint. Gate phê duyệt cuối để chuyển sang
executable tests vẫn chưa được đánh dấu vì người dùng chưa phê duyệt Phase C.

### Artifact Paths

- `tests/api-testing/test-cases/fr-11-phase-c-human-review-workbook.md`
- `reports/ai-audit-report.md` – Entry #5

SHA-256 worksheet:
`9AF3403215F6C8A55404F8063185A6068DC1AAEA9C2F1729CC2A7B19AD8B5BF6`.

### Status

PHASE C: IN PROGRESS
HUMAN CASE-BY-CASE AUDIT: COMPLETE
HUMAN-ADDED CASES: 10 COMPLETE
HUMAN FINAL APPROVAL FOR PHASE D: PENDING
NEXT PHASE GATE: D – LOCKED
EXECUTION: NOT EXECUTED
```

Đánh giá/chỉnh sửa của con người:

PENDING

Entry #6

AI Audit Entry

Tool: Codex (GPT-5)

Date: 21/08/2026 00:18 – Asia/Ho_Chi_Minh

User Prompt:

approved, continue

AI Output:

Phase C final approval was recorded and Phase D was performed for FR-11 only.

The executable collection contains 42 cases: all 33 AI cases labelled VALID and 9 human-origin cases. The 2 INVALID and 35 INCOMPLETE AI cases were excluded. FR11-MYO-H03 was not automated because controlled database fault injection and an exact oracle remain unspecified.

Newman 6.2.2 executed 53 requests and 101 assertions. Result: 92 assertions passed, 9 failed, exit code 1. All nine failures affect GET /api/orders/:id and were classified LOI_BAO_MAT_SUT because protected order data was disclosed under foreign, absent, empty, malformed, tampered, expired, or unsupported authentication.

Raw console, JSON, HTML, metadata, collection, environment, data, fixture scripts and a separate analysis report were retained. X-Student-Id was logged for all 42 subject requests with no header assertion failure. A real Postman header screenshot remains PENDING HUMAN CAPTURE and was not fabricated.

PHASE D: COMPLETE
EXECUTION: EXECUTED – FAILED
HUMAN ASSESSMENT: PENDING

Đánh giá/chỉnh sửa của con người:

PENDING

Entry #7

AI Audit Entry

Tool: **Codex (GPT-5)**

Date: **21/08/2026 00:52 – Asia/Ho_Chi_Minh**

User Prompt:

tôi đã bổ sung các tài liệu còn thiếu tại phase D, rà soát lại và cung cấp nội dung cần thực hiện tiếp theo

AI Output:

Đã rà soát lại artifact Phase D của FR-11. Ảnh postman-header-screenshot.png là ảnh Postman Console thực tế, hiển thị đúng collection/request FR-11, localhost:3000 và request header X-Student-Id: 23127464; hạng mục screenshot có thể chuyển từ PENDING sang PROVIDED.

Collection, raw console, JSON report và HTML report của canonical Newman run vẫn nguyên vẹn. File environment hiện tại được sinh lại sau canonical run và có bảy token được tái tạo; vì vậy cần đồng bộ environment chính xác từ Newman JSON report hoặc tạo evidence manifest/addendum thay vì coi file environment hiện tại là bản đã dùng cho canonical run.

Việc tiếp theo: đồng bộ execution analysis/evidence manifest với screenshot; con người xác nhận hoặc chỉnh sửa phân loại chín failure; quyết định oracle và cơ chế fault injection cho FR11-MYO-H03; chỉ sau khi được duyệt mới chuyển Phase E để lập bug report Markdown, còn xuất bản GitHub Issue cần yêu cầu riêng.

Đánh giá/chỉnh sửa của con người:

PENDING

Entry #8

AI Audit Entry

Tool: Codex (GPT-5)

Date: 21/08/2026 01:26 — Asia/Ho_Chi_Minh

User Prompt:

Thiết lập CI/CD cho FR-11:

1. Tạo ``.github/workflows/fr-11-api-test.yml`` với checkout, Node.js 22, cài backend, chạy SUT và health check, cài Newman/htmlextra, chạy fixture/Newman và upload HTML report.
2. Tạo commit all-pass bằng folder ``GET /api/orders/my-orders``, push, chạy pipeline và ghi bằng chứng.
3. Tạo commit full collection có failure, push, chạy pipeline và ghi bằng chứng.
4. Tạo ``reports/api-testing/fr-11-cicd-report.md`` với hai run và dùng PENDING cho bằng chứng chưa tồn tại.
5. Không bịa link, screenshot hoặc commit hash.

AI Output:

Đã tạo và push workflow GitHub Actions FR-11. Lần bootstrap tại commit 528b66aee41d9e73fb85448e65504d399eae0da8 thất bại ở Setup Node.js vì backend bị gitignore và chưa có trên runner; Newman chưa chạy. Sau khi bổ sung bốn file backend runtime tối thiểu, run all-pass folder my-orders tại commit fa490400e8145ecc72685328e15542d9ae79e051 hoàn tất SUCCESS:
<https://github.com/lmch khi/CS423-CSC15003-Testing-N08/actions/runs/32402724185>.

Đã bỏ folder filter và push commit full collection

fa469cff4cdf4de5ea71cc2883d182c730684132. Run hoàn tất FAILURE tại bước Enforce Newman result: <https://github.com/lmchkh/CS423-CSC15003-Testing-N08/actions/runs/32403028362>. Cả hai run có artifact Newman/HTML thật. GitHub API công khai trả 403 khi tải log/artifact chi tiết, nên screenshot và việc đối chiếu assertion trực tiếp từ artifact vẫn PENDING; không tạo bằng chứng giả.

Báo cáo CI/CD được cập nhật tại `reports/api-testing/fr-11-cicd-report.md`. Workflow cuối chạy toàn bộ collection. Bug report untracked không được đưa vào các commit CI.

Đánh giá/chỉnh sửa của con người:

PENDING

Entry #9

AI Audit Entry

Tool: Codex (GPT-5)

Date: 21/08/2026 01:35 — Asia/Ho_Chi_Minh

User Prompt:

Hoàn thiện Phase E cho FR-11 (Pool B). Thực hiện tất cả các việc sau:

- Cập nhật CI/CD report ``reports/api-testing/fr-11-cicd-report.md``:
 - Điền link, commit hash, screenshot path cho 2 runs nếu còn PENDING.
 - Kiểm tra nội dung đầy đủ theo đề bài: pipeline configuration + 2 runs.
- Cập nhật ``README.md`` (file gốc ở root repo) thêm section FR-11 (Pool B) summary:
 - API đã chọn: FR-11, GET `/api/orders/my-orders`, GET `/api/orders/:id`
 - Test case: 70 AI-sinh, 10 human bổ sung, tổng 80
 - Audit: 33 VALID, 2 INVALID, 35 INCOMPLETE
 - Executed: 42 ca, 101 assertions, 92 passed, 9 failed
 - Bug: 1 (IDOR + missing auth trên GET `/api/orders/:id`)
 - Postman features đã dùng: collections, variables, environments, pre-request scripts, test scripts, Collection Runner with data file, Newman CLI with `htmlextra` reporter
 - Ghi theo format bảng assessment template trong đề bài nếu phù hợp.
- Cập nhật trạng thái cuối:
PHASE E: COMPLETE
Liệt kê deliverables đã hoàn thành và deliverables còn thiếu (sơ đồ tự vẽ, video demo nếu có).

Không bịa commit hash, link, hay screenshot. Ghi PENDING cho phần chưa có.

AI Output:

Đã kiểm tra trực quan hai ảnh GitHub Actions thật và xác nhận chúng khớp run all-pass 32402724185 và run failure 32403028362. CI/CD report được điền đường dẫn ảnh, SHA-256 ảnh, link run, artifact URL, commit SHA và trạng thái thực thi; pipeline configuration cùng hai run đều hiện diện.

README root được bổ sung summary FR-11 Pool B theo dạng assessment table: 70 AI-generated, 10 human-added, tổng 80; audit 33 VALID, 2 INVALID, 35 INCOMPLETE; thực thi 42 ca với 101 assertions, 92 passed và 9 failed; một bug IDOR + missing authentication. README chỉ liệt kê các Postman/Newman features thực sự dùng.

PHASE E được đánh dấu COMPLETE. Các mục chưa có được giữ rõ: authenticated CI assertion detail review PENDING, GitHub Issue NOT CREATED, sơ đồ tự vẽ PENDING và video FR-11 NOT PROVIDED.

Đánh giá/chỉnh sửa của con người:

PENDING

Entry #10

AI Audit Entry

Tool: Codex (GPT-5)

Date: 21/08/2026 01:44 – Asia/Ho_Chi_Minh

Purpose: PHASE A – chọn phạm vi và trích xuất contract chỉ cho FR-16 / POST /api/admin/import-products

User Prompt:

sử dụng ai-first-api-testing thực hiện:

- Pool C
- FR-16 – Product Import from CSV
- Endpoint thuộc phạm vi:
 - POST /api/admin/import-products

NGUYÊN TẮC PHẠM VI

Chỉ tập trung vào FR-16 và POST /api/admin/import-products.

Không phân tích, mô tả, tạo test hoặc mở rộng sang bất kỳ FR hay endpoint admin nào khác.

Chỉ sử dụng các rule authentication/admin/security nếu chúng trực tiếp ảnh hưởng đến FR-16.

Không trình bày tổng quan Pool C hoặc các chức năng admin khác.

TÀI LIỆU CẦN DỪNG

Đọc và tuân thủ:

- SKILL.md
- references/phase-playbook.md
- references/api-selection-contract.md
- references/api-testing-runbook.md
- references/assignment-requirements.md
- src/eshop-sut/api_specification.md
- src/eshop-sut/README.md

Chỉ đọc source code nếu cần xác minh contract conflict trực tiếp của FR-16.

PHẠM VI THỰC THI

Chỉ thực hiện:

PHASE A – CHỌN PHẠM VI / TRÍCH XUẤT CONTRACT CHO FR-16

Không được:

- sinh test cases;
- audit;
- human extension;
- tạo executable tests;
- chạy Postman/Newman;
- báo bug;
- CI/CD;
- tổng hợp report;
- chuyển sang Phase B.

Sau Phase A phải DỪNG.

NHIỆM VỤ

1. Xác minh endpoint:
POST /api/admin/import-products
2. Trích xuất contract chỉ cho FR-16:
 - authentication;
 - admin authorization;
 - request representation;
 - product fields;
 - validation rules;
 - CSV format rules;
 - RFC 4180 nếu có;
 - rollback/atomicity;
 - result reporting;
 - category/data dependency;
 - documented response/schema;
 - spec gaps.

3. Kiểm tra trực tiếp conflict của FR-16:

README có thể mô tả:

- upload file .csv;
- header:
name,price,description,imageUrl,category_id
- RFC 4180;
- name không rỗng;
- price > 0;
- một dòng lỗi thì rollback toàn bộ.

API specification có thể mô tả:

- POST /api/admin/import-products
- JSON body chứa products array.

Phải tự xác minh lại từ tài liệu.

Nếu đúng là có mâu thuẫn thì ghi:

SPEC GAP / CONTRACT CONFLICT

Không tự chọn CSV hay JSON làm contract cuối.

Nếu source code dùng một format, chỉ ghi:

IMPLEMENTATION OBSERVATION

không tự coi đó là expected contract.

4. Xây dựng planned partition model cho riêng FR-16:

- valid import;
- invalid file/request representation;
- empty input;
- header issues;
- malformed rows;
- quoted comma fields;
- name validation;
- price validation;
- category_id dependency;
- one invalid row among valid rows;
- rollback/atomicity;
- admin vs non-admin vs unauthenticated.

5. Chỉ áp dụng security concern liên quan trực tiếp:

- missing/invalid auth;
- non-admin access;
- unauthorized bulk mutation;
- injection-oriented imported values nếu phù hợp.

Không mở rộng sang các admin API khác.

6. Không tự bịa:

- exact status code;

- response body;
- exact response schema;
- import format;
- error reporting format.

Nếu thiếu nguồn, ghi:

INCOMPLETE / SPEC GAP

7. Tạo mục riêng:

HUMAN DECISION REQUIRED

Nêu ngắn gọn:

- README nói gì;
- API specification nói gì;
- conflict nằm ở đâu;
- phần nào của Phase B bị ảnh hưởng;
- AI không tự chọn contract.

Trạng thái:

CONTRACT DECISION: PENDING HUMAN REVIEW

8. Xác định Student ID nhưng không execute request.

9. Chỉ tạo/cập nhật artifact cho Phase A của FR-16.

10. Ghi AI Audit cho interaction này.

OUTPUT CUỐI

Chỉ báo cáo:

FR-16 Scope

Contract

Authentication / Admin Requirement

Contract Conflict

HUMAN DECISION REQUIRED

Inputs / Planned Partitions

Applicable Security

Spec Gaps

Data Dependencies

Artifact Paths

Status

Dừng:

PHASE A: COMPLETE

CONTRACT DECISION: PENDING HUMAN REVIEW

HUMAN REVIEW: PENDING

NEXT ALLOWED PHASE: B – AI GENERATION

EXECUTION: NOT EXECUTED

Sau đó DỪNG.

Không được tự động chạy Phase B.

AI Output:

FR-16 Scope

Đã xác minh Pool C, FR-16 – Product Import from CSV, với endpoint duy nhất `POST /api/admin/import-products`. Student ID là `23127464`; chưa gửi request.

Contract

README quy định file `.csv`, header `name,price,description,imageUrl,category\_id`, quoted comma theo RFC 4180, `name` không rỗng, `price > 0`, rollback toàn bộ nếu một dòng lỗi và báo số dòng thành công/lỗi kèm lý do. API specification công bố JSON `{ "products": [...] }`. Không có exact status code, response body/schema hay error-reporting format.

Authentication / Admin Requirement

Endpoint yêu cầu JWT hợp lệ qua `Authorization: Bearer <token>` và `role = 'admin'`. Exact rejection status/body là `INCOMPLETE / SPEC GAP`.

Contract Conflict

****SPEC GAP / CONTRACT CONFLICT**** – README yêu cầu CSV upload, còn API specification yêu cầu JSON products array. Source nhận JSON array nhưng đây chỉ là ****IMPLEMENTATION OBSERVATION****, không phải expected contract.

HUMAN DECISION REQUIRED

README và API specification mâu thuẫn tại request representation. Quyết định này ảnh hưởng trực tiếp đến Content-Type/body, empty-input/header/malformed-row/quoted-comma partitions và executable design của Phase B. AI không tự chọn CSV hay JSON.

CONTRACT DECISION: PENDING HUMAN REVIEW

Inputs / Planned Partitions

Artifact đã hoạch định riêng các partition: valid import; invalid representation;

empty input; header issues; malformed rows; quoted comma; `name`; `price`; `category\_id`; một dòng invalid giữa các dòng valid; rollback/atomicity; admin/non-admin/unauthenticated.

Applicable Security

Chỉ áp dụng missing/invalid JWT, non-admin access, unauthorized bulk mutation và giá trị import hướng injection theo SEC-02/SEC-03/SEC-04/SEC-05.

Spec Gaps

Các khoảng trống gồm representation cuối, upload/Content-Type, phạm vi RFC 4180, header policy, field schema/validation, category dependency, atomic/error semantics, status codes và exact response/error schema; tất cả được ghi `INCOMPLETE / SPEC GAP`.

Data Dependencies

Cần admin/non-admin JWT fixtures, category tồn tại/không tồn tại, valid/invalid product batches, baseline kiểm tra rollback, isolation/reset và `X-Student-Id: 23127464` cho phase thực thi tương lai.

Artifact Paths

- `reports/api-testing/fr-16-phase-a-contract.md`
- `reports/ai-audit-report.md` – Entry #10

Status

PHASE A: COMPLETE
CONTRACT DECISION: PENDING HUMAN REVIEW
HUMAN REVIEW: PENDING
NEXT ALLOWED PHASE: B – AI GENERATION
EXECUTION: NOT EXECUTED

Đánh giá/chỉnh sửa của con người:

PENDING

Entry #11

AI Audit Entry

Tool: Codex (GPT-5)

Date: 21/08/2026 02:06 – Asia/Ho_Chi_Minh

Purpose: PHASE B – AI generation chỉ cho FR-16 / POST /api/admin/import-products

User Prompt:

Đọc và tuân thủ:

- ai-first-api-testing/SKILL.md
- ai-first-api-testing/references/phase-playbook.md
- ai-first-api-testing/references/api-testing-runbook.md
- reports/api-testing/fr-16-phase-a-contract.md

HUMAN CONTRACT DECISION

Con người đã quyết định contract conflict giữa README (CSV upload) và API spec (JSON array):

- PRIMARY: Test JSON array – endpoint thực tế nhận `Content-Type: application/json` với body `{ "products": [...] }`. Đây là contract chính cho test.
- SECONDARY: Thêm 1-2 ca gửi CSV file upload (multipart/form-data) để document spec conflict. Expected: server reject hoặc không xử lý đúng vì endpoint nhận JSON.
- Ghi rõ trong output: HUMAN DECISION – JSON array là primary contract, CSV upload là exploratory/negative test cho spec conflict.

PHẠM VI

Pool C, FR-16, POST /api/admin/import-products.

Student ID: 23127464.

Chỉ thực hiện PHASE B – AI GENERATION.

Không audit, không extend, không execute, không báo bug.

Sau Phase B phải DỪNG.

YÊU CẦU SINH TEST CASE

Sinh ít nhất 35 test case cho endpoint POST /api/admin/import-products.

Mỗi test case phải có: mã, mục tiêu, dữ liệu đầu vào, kết quả mong đợi, danh mục, truy vết nguồn yêu cầu.

Phân bổ partition – phải bao phủ tất cả nhóm sau:

1. **Valid import (3-4 ca):**

- Import 1 product hợp lệ
- Import nhiều product hợp lệ (batch)
- Product có quoted comma trong description (RFC 4180 context, gửi qua JSON)
- Product với tất cả field đầy đủ

2. **Authentication/Authorization (6-8 ca):**

- Admin + valid JWT → success
- User (non-admin) + valid JWT → reject
- Không có Authorization header → reject
- Authorization rỗng → reject
- Bearer không token → reject
- Token ngẫu nhiên → reject

- JWT hết hạn → reject
- JWT sửa signature → reject

3. ****Name validation (4-5 ca):****

- name rỗng "" → reject/rollback
- name missing (không có key) → reject/rollback
- name null → reject/rollback
- name whitespace-only → INCOMPLETE (spec không định nghĩa)
- name rất dài → INCOMPLETE

4. ****Price validation (5-6 ca):****

- price > 0 hợp lệ
- price = 0 → reject (spec: > 0)
- price âm → reject
- price không phải số (string "abc") → INCOMPLETE
- price null/missing → INCOMPLETE
- price thập phân (1.5) → hợp lệ nếu > 0

5. ****category_id dependency (3-4 ca):****

- category_id tồn tại → success
- category_id không tồn tại → INCOMPLETE (spec không định nghĩa)
- category_id missing → INCOMPLETE (spec không định nghĩa)
- category_id sai kiểu → INCOMPLETE

6. ****Atomicity/Rollback (3-4 ca):****

- 1 dòng invalid giữa các dòng valid → toàn bộ rollback
- Dòng invalid ở đầu batch → rollback
- Dòng invalid ở cuối batch → rollback
- Kiểm tra DB không có product nào sau rollback

7. ****Empty/invalid input (3-4 ca):****

- Body rỗng {} → reject
- products missing → reject
- products = [] (array rỗng) → reject
- products không phải array → reject

8. ****Security/Injection (2-3 ca):****

- SQL injection trong name
- XSS/script trong description
- Import không được tạo product khi auth fail

9. ****Spec conflict – CSV upload (2 ca):****

- Gửi multipart/form-data với file .csv → document spec conflict
- Gửi Content-Type: text/csv với raw CSV body → document spec conflict
- Ghi rõ: HUMAN DECISION – đây là exploratory test cho contract conflict

QUY TẮC

- Không bịa exact status code, response body hay error schema cho expected result. Chỉ dùng semantic assertion: "phải reject", "không được tạo product", "phải rollback toàn bộ".
- Nếu expected result không có nguồn, ghi INCOMPLETE / SPEC GAP.
- Auth/role rejection: chỉ assert "không được import/tạo product", không assert 401/403.
- Rollback assertion: assert "không product nào của batch được lưu vào DB".
- Truy vết nguồn: FR-16, SEC-02, SEC-03, FR-12, API spec §6.3, README.
- Ghi X-Student-Id: 23127464 là precondition chung, không tạo ca riêng.
- Tổng tối thiểu 35 ca.

OUTPUT FORMAT

Tạo file tests/api-testing/test-cases/fr-16-ai-generated-phase-b.md với format:

Bảng test case endpoint POST /api/admin/import-products

Mã	Mục tiêu	Dữ liệu đầu vào	Kết quả mong đợi	Danh mục	Nguồn
----	----------	-----------------	------------------	----------	-------

Traceability matrix

Status

PHASE B: COMPLETE

NEXT ALLOWED PHASE: C – HUMAN REVIEW

EXECUTION: NOT EXECUTED

Ghi AI Audit cho interaction này.

Sau đó DỪNG. Không chạy Phase C.

AI Output:

HUMAN DECISION

JSON array với `Content-Type: application/json` và body `{ "products": [...] }` đã được dùng làm primary contract. Hai ca CSV là exploratory/negative để ghi nhận spec conflict, không thay thế primary contract.

Generated Test Cases

Đã tạo 40 test case AI-sinh cho duy nhất `POST /api/admin/import-products`: 4 valid import, 8 authentication/authorization, 5 name, 6 price, 4 category_id, 4 atomicity/rollback, 4 empty/invalid input, 3 security/injection và 2 CSV conflict. Tất cả ca có mã, mục tiêu, input, semantic expected result, danh mục và nguồn. `X-Student-Id: 23127464` được ghi là precondition chung.

Oracle Discipline

Không dùng exact status code, response body hay response/error schema. Các behavior thiếu nguồn được đánh dấu `INCOMPLETE / SPEC GAP`; auth failure chỉ yêu cầu không import, rollback chỉ yêu cầu không product nào của batch được lưu.

Artifact Paths

- `tests/api-testing/test-cases/fr-16-ai-generated-phase-b.md`
- `reports/ai-audit-report.md` – Entry #11

SHA-256 test-case artifact:

`D813762456F6ED9D2BE2F53566F650EC3DCB1EAC62134ED9CDC36167CD69C44E`.

Status

PHASE B: COMPLETE

NEXT ALLOWED PHASE: C – HUMAN REVIEW

EXECUTION: NOT EXECUTED

Đánh giá/chỉnh sửa của con người:

PENDING

Entry #12

AI Audit Entry

Tool: **Codex** (GPT-5)

Date: **21/08/2026 02:20** – Asia/Ho_Chi_Minh

Purpose: **PHASE C** – tạo human review worksheet chỉ cho FR-16 / POST /api/admin/import-products

User Prompt:

Đọc và tuân thủ:

- ai-first-api-testing/SKILL.md
- ai-first-api-testing/references/phase-playbook.md
- ai-first-api-testing/references/api-testing-runbook.md
- reports/api-testing/fr-16-phase-a-contract.md
- tests/api-testing/test-cases/fr-16-ai-generated-phase-b.md

PHẠM VI

Pool C, FR-16, POST /api/admin/import-products.

Student ID: 23127464.

Chỉ thực hiện PHASE C – HUMAN REVIEW WORKSHEET.

Không execute, không báo bug, không CI/CD.

Sau Phase C phải DỪNG.

HUMAN CONTRACT DECISION (đã chốt từ Phase A)

JSON array là primary contract. CSV upload là exploratory/negative.

NHIỆM VỤ

1. Tính SHA-256 của file `tests/api-testing/test-cases/fr-16-ai-generated-phase-b.md`
và ghi vào worksheet.
2. Tạo file `tests/api-testing/test-cases/fr-16-phase-c-human-review-workbook.md`
với cấu trúc:

Phần A: Bảng kiểm toán AI pre-audit cho 40 ca

Mỗi ca một dòng với các cột:

| Mã | Mô tả rút gọn | Danh mục | Đề xuất AI | Lý do/đề xuất chỉnh sửa của AI |
Kết luận con người | Lý do của con người | Chỉnh sửa cuối cùng |

Quy tắc gán nhãn AI pre-audit:

- VALID: ca có đầu vào, bước, expected result đều có nguồn trực tiếp từ FR-16/SEC-02/SEC-03/FR-12/API spec và thực thi được mà không cần bịa oracle.
- INVALID: ca trùng lặp hoặc ngoài phạm vi FR-16.
- INCOMPLETE: ca có ý nghĩa nhưng thiếu oracle (exact status, schema, field type, coercion rule). Ghi rõ phần nào thiếu.

Cột "Kết luận con người", "Lý do của con người", "Chỉnh sửa cuối cùng" để PENDING.

3. Thống kê đề xuất AI: số VALID, INVALID, INCOMPLETE.

Phần B: Vùng ca kiểm thử do con người bổ sung

Tạo bảng 5 slot PENDING cho endpoint POST /api/admin/import-products:

| Slot | Mã do người review đặt | Mục tiêu / kết quả mong đợi | Nguồn yêu cầu |
Lý do AI bỏ sót | Xác nhận do con người tạo |

5 slot với giá trị PENDING.

Phần C: Gate Phase C

Checklist:

- [] Con người đã gán nhãn cho 40/40 ca.
- [] Mọi ca INVALID/INCOMPLETE có lý do và chỉnh sửa cuối cùng.
- [] Đã bổ sung ít nhất 5 ca human-origin.
- [] Mỗi ca human-origin có nguồn và lý do AI bỏ sót.
- [] Bản cuối đã được con người phê duyệt để chuyển sang executable tests.

Trạng thái

PHASE C: IN PROGRESS

AI PRE-AUDIT: COMPLETE

HUMAN CASE-BY-CASE AUDIT: PENDING

HUMAN-ADDED CASES: PENDING

EXECUTION: NOT EXECUTED

4. Ghi AI Audit cho interaction này.
Sau đó DỪNG. Không chạy Phase D.

AI Output:

Worksheet

Đã tạo worksheet Phase C cho đủ 40/40 ca FR-16. SHA-256 của Phase B artifact được ghi là `D813762456F6ED9D2BE2F53566F650EC3DCB1EAC62134ED9CDC36167CD69C44E`.

AI Pre-audit

Đề xuất AI: 29 `VALID`, 2 `INVALID`, 9 `INCOMPLETE`. Hai ca `INVALID` là `FR16-VLD-004` (trùng semantic với `FR16-VLD-001`) và `FR16-SEC-003` (trùng semantic với `FR16-AUTH-006`). Cả 40 dòng giữ ba cột quyết định con người ở `PENDING`.

Human-added Slots / Gate

Đã tạo đúng 5 slot human-origin với toàn bộ giá trị `PENDING`. Năm gate Phase C đều chưa được đánh dấu vì chưa có quyết định hoặc ca bổ sung từ con người.

Artifact Paths

- `tests/api-testing/test-cases/fr-16-phase-c-human-review-workbook.md`
- `reports/ai-audit-report.md` – Entry #12

SHA-256 workbook:

`0435B02836FBE7AB480DBD808193F8BF6A0A94D8D19A0279338A9F62671D0372`.

Trạng thái

PHASE C: IN PROGRESS

AI PRE-AUDIT: COMPLETE

HUMAN CASE-BY-CASE AUDIT: PENDING

HUMAN-ADDED CASES: PENDING

EXECUTION: NOT EXECUTED

Đánh giá/chỉnh sửa của con người:

PENDING

Entry #13

AI Audit Entry

Tool: Codex (GPT-5)

Date: 21/08/2026 02:25 – Asia/Ho_Chi_Minh

Purpose: Điền 5 ca CON-NGUOI-BO-SUNG vào Phần B của FR-16 Phase C worksheet

User Prompt:

Đọc file tests/api-testing/test-cases/fr-16-phase-c-human-review-workbook.md phần B.
Điền 5 ca kiểm thử vào 5 slot PENDING. Nguồn gốc: CON-NGUOI-BO-SUNG.
Không sửa phần A và Gate.

1. FR16-H01 – Gửi GET /api/admin/import-products với admin JWT hợp lệ → server reject,
không import. Nguồn: API spec chỉ công bố POST. Lý do AI bỏ sót: AI không test method mismatch.

2. FR16-H02 – Gửi products array 500+ object hợp lệ → INCOMPLETE, spec không định nghĩa
batch size limit, server không được crash. Nguồn: Phase A spec gap batch/file size.
Lý do AI bỏ sót: AI chỉ test batch nhỏ 1-3 product.

3. FR16-H03 – Gửi batch có 2 product cùng name và category_id → INCOMPLETE, spec không
định nghĩa duplicate handling. Nguồn: Phase A spec gap duplicate product.
Lý do AI bỏ sót: AI không xét duplicate logic.

4. FR16-H04 – Gửi product có extra field không thuộc schema (ví dụ malicious_field) →
extra field phải bị bỏ qua, chỉ 5 field công bố được lưu, không side effect.
Nguồn: API spec §6.3 chỉ công bố 5 field, SEC-05.
Lý do AI bỏ sót: AI test field thiếu/sai nhưng không test thừa field.

5. FR16-H05 – User thường (non-admin) gửi batch 3 product hợp lệ, kiểm tra DB trước/sau → không product nào được tạo. Nguồn: FR-12/SEC-03 + atomicity.
Lý do AI bỏ sót: AI có AUTH-002 reject non-admin nhưng không verify DB persistence,
SEC-003 bị đánh INVALID nên thiếu coverage persistence cho non-admin.

AI Output:

Phần B

Đã điền đủ 5 slot bằng `FR16-H01`-`FR16-H05`. Mỗi ca giữ nguyên mục tiêu/kết quả mong đợi, nguồn yêu cầu và lý do AI bỏ sót do con người cung cấp; cột xác nhận nguồn gốc là `CON-NGUOI-BO-SUNG`.

`FR16-H02` và `FR16-H03` được giữ rõ `INCOMPLETE / SPEC GAP`. Không có request nào được thực thi.

Phạm vi thay đổi

Chỉ Phần B của worksheet được sửa. Phần A và toàn bộ Gate Phase C vẫn giữ nguyên,

chưa đánh dấu checklist.

Artifact Paths

- `tests/api-testing/test-cases/fr-16-phase-c-human-review-workbook.md`
- `reports/ai-audit-report.md` – Entry #13

SHA-256 workbook sau cập nhật:

`6AF12F4FD27A1D8ABF16591D8863311F5702C1C4F77413E186BE4F63D147ACB0`.

Đánh giá/chỉnh sửa của con người:

PENDING

Entry #14

AI Audit Entry

Tool: **Codex (GPT-5)**

Date: **21/08/2026 02:33 – Asia/Ho_Chi_Minh**

Purpose: **Ghi quyết định human case-by-case audit cho 40 ca FR-16 và cập nhật Phase C gate**

User Prompt:

Điền cột "Kết luận con người", "Lý do của con người" và "Chỉnh sửa cuối cùng" cho 40 ca trong file tests/api-testing/test-cases/fr-16-phase-c-human-review-workbook.md.

Không sửa các cột khác. Không sửa phần B.

Quy tắc gán nhãn:

- VALID: đầu vào, bước, expected result có nguồn và thực thi được. Chỉnh sửa = "N/A".
- INVALID: trùng lặp hoặc ngoài phạm vi. Ghi lý do cụ thể.
- INCOMPLETE: có ý nghĩa nhưng thiếu oracle. Ghi phần nào thiếu.

Gán nhãn cụ thể:

- VALID cho: VLD-001, VLD-002, VLD-003, AUTH-001 đến AUTH-008, NAME-001, NAME-002, PRICE-001, PRICE-002, PRICE-003, PRICE-006, CAT-001, ATOM-001 đến ATOM-004, INPUT-001 đến INPUT-004, SEC-001, CSV-001, CSV-002.
- INVALID cho: VLD-004 (trùng VLD-001), SEC-003 (trùng AUTH-006).
- INCOMPLETE cho: NAME-003, NAME-004, NAME-005, PRICE-004, PRICE-005, CAT-002, CAT-003, CAT-004, SEC-002.

Lý do VALID: viết cụ thể cho từng ca, KHÔNG dùng cùng 1 câu cho tất cả.

Lý do INCOMPLETE: ghi dựa trên cột "Lý do/đề xuất chỉnh sửa của AI".

Cập nhật trạng thái:

- HUMAN CASE-BY-CASE AUDIT: COMPLETE
- HUMAN-ADDED CASES: 5 COMPLETE
- Tick checkbox gate tương ứng.
- Checkbox cuối "Bản cuối phê duyệt" để trống.

AI Output:

Human Audit Results

Đã điền đúng ba cột human audit cho 40/40 ca, không sửa năm cột nội dung AI. Kết quả: 29 `VALID`, 2 `INVALID`, 9 `INCOMPLETE`; không còn quyết định `PENDING`. Cả 29 ca `VALID` có `Chỉnh sửa cuối cùng = N/A`, với lý do riêng cho từng ca.

Hai ca `INVALID` được ghi cụ thể: `FR16-VLD-004` trùng `FR16-VLD-001`; `FR16-SEC-003` trùng `FR16-AUTH-006`. Chín ca `INCOMPLETE` ghi rõ oracle còn thiếu và điều kiện cần trước khi đưa vào executable suite.

Phase C Gate

Phần B giữ nguyên 5 ca `CON-NGUOI-BO-SUNG`. Bốn checkbox tương ứng với audit hoàn tất, lý do/chỉnh sửa hoàn tất và human-added cases đã được tick. Checkbox phê duyệt cuối vẫn để trống.

Artifact Paths

- `tests/api-testing/test-cases/fr-16-phase-c-human-review-workbook.md`
- `reports/ai-audit-report.md` – Entry #14

SHA-256 workbook:

`F77FBEE8D1744E3FA220372B6A6E6A4AE0748661E0704AE151B4361B1145B0E5`.

Status

PHASE C: IN PROGRESS

HUMAN CASE-BY-CASE AUDIT: COMPLETE

HUMAN-ADDED CASES: 5 COMPLETE

HUMAN FINAL APPROVAL FOR PHASE D: PENDING

EXECUTION: NOT EXECUTED

Đánh giá/chỉnh sửa của con người:

PENDING

Entry #15

AI Audit Entry

Tool: **Codex (GPT-5)**

Date: **21/08/2026 02:53 – Asia/Ho_Chi_Minh**

Purpose: **PHASE D – execution chỉ cho FR-16 / POST /api/admin/import-products**

User Prompt:

Đọc và tuân thủ:

- ai-first-api-testing/SKILL.md
- ai-first-api-testing/references/phase-playbook.md
- ai-first-api-testing/references/api-testing-runbook.md
- reports/api-testing/fr-16-phase-a-contract.md
- tests/api-testing/test-cases/fr-16-ai-generated-phase-b.md
- tests/api-testing/test-cases/fr-16-phase-c-human-review-workbook.md

PHẠM VI

Pool C, FR-16, POST /api/admin/import-products.

Student ID: 23127464.

Chỉ thực hiện PHASE D – EXECUTION.

Không báo bug, không CI/CD, không tổng hợp.

Sau Phase D phải DỪNG.

HUMAN CONTRACT DECISION

JSON array là primary contract. CSV upload là exploratory/negative.

Phase C đã approved – checkbox cuối được tick.

NHIỆM VỤ

1. Chọn ca để tự động hóa:

- 29 ca AI VALID + tối đa ca human-origin có oracle đủ.
- KHÔNG tự động hóa 9 ca INCOMPLETE và 2 ca INVALID.
- FR16-H02 (batch 500+) và FR16-H03 (duplicate) là INCOMPLETE → không bắt buộc.
- FR16-H01 (method mismatch), FR16-H04 (extra field), FR16-H05 (non-admin DB check)

có oracle → tự động hóa.

- Ghi rõ bao nhiêu ca được tự động hóa, bao nhiêu loại trừ.

2. Tạo fixture script tại tests/api-testing/scripts/prepare-fr16-fixture.js:

- Tạo admin user (hoặc dùng admin sẵn có) + non-admin user.
- Tạo ít nhất 1 category fixture ổn định.
- Ký JWT tokens: admin valid, non-admin valid, expired, tampered payload, tampered signature, missing identity.
- Ghi baseline product count trước import tests.
- Xuất environment JSON tại tests/api-testing/environments/fr-16-

local.postman_environment.json.

3. Tạo Postman collection tại

tests/api-

testing/collections/23127464_FR16_Product_Import.postman_collection.json:

- Collection-level pre-request script upsert X-Student-Id: 23127464.
- Mỗi ca là 1 request với test script (pm.test).
- Auth tests: assert response không chứa marker import success.
- Valid import: dùng marker name duy nhất, kiểm tra import thành công.
- Rollback/atomicity: gửi batch mixed valid+invalid, sau đó kiểm tra marker products KHÔNG tồn tại (dùng pm.sendRequest GET products nếu cần).
- CSV exploratory: gửi multipart hoặc text/csv, assert không import.
- KHÔNG bịa exact status code cho auth rejection – chỉ assert semantic (response không chứa marker, status >= 400 cho method mismatch).

4. Tạo data file tests/api-testing/data/fr-16-run-data.json.

5. Tạo runner script:

- tests/api-testing/scripts/run-fr16-newman.js hoặc .ps1
- Start SUT, health check, run fixture, run Newman với cli+json+htmlextra.
- Lưu evidence vào tests/api-testing/evidence/fr-16/<timestamp>/.

6. Chạy Newman và lưu evidence:

- newman-console.txt, newman-report.json, newman-report.html
- execution-metadata.json (command, versions, timestamps, exit code, SHA-256)
- Giữ tất cả runs kể cả thất bại.

7. Phân loại failure:

- Nếu test fail, phân loại LOI_MOI_TRUONG, LOI_SCRIPT, hoặc LOI_BAO_MAT_SUT trước khi kết luận.
- Tạo execution analysis tại reports/api-testing/fr-16-phase-d-execution-analysis.md.
- Tạo execution plan tại reports/api-testing/fr-16-phase-d-execution-plan.md.

8. Ghi AI Audit cho interaction này.

9. Trạng thái cuối:

PHASE D: COMPLETE hoặc IN PROGRESS (tùy kết quả)

HUMAN ASSESSMENT: PENDING

HEADER SCREENSHOT: PENDING HUMAN CAPTURE (dùng chung screenshot FR-11 nếu được)

Sau đó DỪNG. Không chạy Phase E.

AI Output:

Selection

Đã tự động hóa 32 ca: 29 AI `VALID` và ba ca human-origin `FR16-H01`, `FR16-H04`, `FR16-H05`. Đã loại 13 ca khỏi collection: 9 AI `INCOMPLETE`, 2 AI `INVALID`, cùng `FR16-H02`/`H03` chưa đủ oracle.

Execution

Canonical run `20260821-024915` chạy 32 items, 63 HTTP requests, 32 test scripts, 33 pre-request scripts và 77 assertions. Kết quả: 69 assertions passed, 8 failed; Newman exit code 1. Host là `http://127.0.0.1:3000`. Node `v22.18.0`, Newman

`6.2.2`, htmlextra `1.23.1`.

Hai attempt trước được giữ nguyên: `20260821-024805` dừng do `LOI\_MOI\_TRUONG` khi fixture chạy trước SQLite schema; `20260821-024833` có một `LOI\_SCRIPT` ở AUTH-003 và được sửa trước canonical run.

Failure Classification

Canonical run không còn lỗi môi trường/script. `FR16-AUTH-002` và `FR16-H05` được phân loại `LOI\_BAO\_MAT\_SUT` vì non-admin đã tạo product. `FR16-PRICE-002`, `PRICE-003`, `ATOM-001`-`004` được phân loại `LOI\_CHUC\_NANG\_SUT` theo taxonomy của skill vì price không hợp lệ vẫn được lưu và mixed batch không rollback. Đây chưa phải bug report hoặc kết luận cuối của con người.

Evidence

Raw console, JSON, HTML, fixture output, SUT log, exact command và metadata có timestamps, versions, exit code, SHA-256 đã được lưu tại `tests/api-testing/evidence/fr-16/20260821-024915/`. Execution plan và analysis đã được tạo. Database được backup trước mỗi attempt.

Tất cả subject request có collection-level `X-Student-Id: 23127464`; không có header assertion failure. Screenshot FR-11 không được tái sử dụng vì không chứng minh header trên request FR-16.

Artifact Paths

- `tests/api-testing/collections/23127464\_FR16\_Product\_Import.postman\_collection.json`
- `tests/api-testing/environments/fr-16-local.postman\_environment.json`
- `tests/api-testing/data/fr-16-run-data.json`
- `tests/api-testing/scripts/prepare-fr16-fixture.js`
- `tests/api-testing/scripts/run-fr16-newman.js`
- `tests/api-testing/evidence/fr-16/20260821-024915/`
- `reports/api-testing/fr-16-phase-d-execution-plan.md`
- `reports/api-testing/fr-16-phase-d-execution-analysis.md`
- `reports/ai-audit-report.md` – Entry #15

Status

PHASE D: COMPLETE
EXECUTION: EXECUTED – FAILED
HUMAN ASSESSMENT: PENDING
HEADER SCREENSHOT: PENDING HUMAN CAPTURE

Đánh giá/chỉnh sửa của con người:

PENDING

Entry #16

AI Audit Entry

Tool: Codex (GPT-5)

Date: 21/08/2026 03:14 – Asia/Ho_Chi_Minh

Purpose: Hoàn thiện evidence và trạng thái PHASE D cho FR-16 / POST /api/admin/import-products

User Prompt:

Hoàn thiện Phase D cho FR-16. Chỉ Phase D, KHÔNG thực hiện Phase E.

1. Cập nhật reports/api-testing/fr-16-phase-d-execution-analysis.md:

- Đổi HEADER SCREENSHOT: PENDING HUMAN CAPTURE thành HEADER SCREENSHOT: PROVIDED

- Đổi HUMAN ASSESSMENT: ĐANG CHỜ thành HUMAN ASSESSMENT: XÁC NHẬN – 2 LOI_BAO_MAT_SUT + 6 LOI_CHUC_NANG_SUT

- Thêm section "Evidence addendum" ghi:

- Đường dẫn: tests/api-testing/evidence/fr-16/postman-header-screenshot.png

- Thời gian chụp: 2026-08-21 03:09 (Asia/Ho_Chi_Minh)

- Tính SHA-256 của file tests/api-testing/evidence/fr-16/postman-header-screenshot.png

- và thêm vào bảng SHA-256 hiện có

- Cập nhật trạng thái cuối:

- PHASE D: COMPLETE

- HUMAN ASSESSMENT: XÁC NHẬN

- HEADER SCREENSHOT: PROVIDED

2. Tạo evidence manifest nếu chưa có tại

tests/api-testing/evidence/fr-16/20260821-024915/evidence-manifest.md

liệt kê tất cả artifact trong canonical run kèm SHA-256 và thêm dòng screenshot.

3. Không tạo bug report. Không viết AI critique. Không cập nhật README.

Không tạo CI/CD. Không thực hiện Phase E.

AI Output:

Đã hoàn thiện Phase D cho FR-16. Ảnh Postman được kiểm tra trực quan, cho thấy request FR16-AUTH-003 có header X-Student-Id: 23127464. SHA-256 của ảnh là BB9B72072C95796A39D137C8CB87D13A79A036406439877AF0133360A0A1E34F.

Execution analysis, canonical metadata và evidence manifest đã được đồng bộ với ảnh, thời gian chụp và kết luận con người: 2 LOI_BAO_MAT_SUT + 6 LOI_CHUC_NANG_SUT.

PHASE D: COMPLETE
HUMAN ASSESSMENT: XÁC NHẬN
HEADER SCREENSHOT: PROVIDED

Không tạo bug report, AI critique, README, CI/CD và không thực hiện Phase E.

Đánh giá/chỉnh sửa của con người:

PENDING

Entry #17

AI Audit Entry

Tool: **Codex** (GPT-5)

Date: 21/08/2026 03:26 – Asia/Ho_Chi_Minh

Purpose: PHASE E – local bug reporting và README summary cho FR-16 / POST
/api/admin/import-products

User Prompt:

Thực hiện Phase E cho FR-16. Đọc trước:

- reports/api-testing/fr-16-phase-d-execution-analysis.md
- tests/api-testing/test-cases/fr-16-phase-c-human-review-workbook.md
- reports/api-testing/fr-16-phase-a-contract.md
- src/eshop-sut/backend/server.js dòng 198-241

NHIỆM VỤ

1. Tạo 3 bug reports tại bug-report/:

- bug-report/fr-16-missing-admin-role-check.md:
 - Tiêu đề: POST /api/admin/import-products thiếu kiểm tra role admin
 - Mức độ: Critical / Security
 - Mô tả: endpoint gán authenticateToken nhưng không kiểm tra role=admin trong JWT payload. User thường có JWT hợp lệ vẫn import được product vào DB.
 - Bước tái hiện: curl với JWT non-admin + batch product hợp lệ
 - Expected: reject, không tạo product (FR-12, SEC-03)
 - Actual: 200 OK, product được lưu vào DB
 - Evidence: FR16-AUTH-002, FR16-H05 trong canonical run 20260821-024915
 - Root cause: server.js:199 chỉ gán authenticateToken, middleware tại :100-110 chỉ verify JWT signature/expiry nhưng không check req.user.role === 'admin'
 - Nguồn: FR-12, SEC-03, API spec Admin section
 - GitHub Issue: NOT CREATED

- b. bug-report/fr-16-missing-price-validation.md:
- Tiêu đề: POST /api/admin/import-products không validate price > 0
 - Mức độ: Medium / Functional
 - Mô tả: README FR-16 yêu cầu price > 0 nhưng endpoint chấp nhận price=0 và price âm, lưu vào DB
 - Bước tái hiện: admin JWT + product với price=0, admin JWT + product price=-1
 - Expected: reject dòng lỗi, rollback batch (FR-16)
 - Actual: product được import thành công
 - Evidence: FR16-PRICE-002, FR16-PRICE-003 trong canonical run
 - Root cause: server.js:213-217 chỉ kiểm tra !row.name, không kiểm tra price <= 0
 - Nguồn: README FR-16
- c. bug-report/fr-16-missing-atomicity-rollback.md:
- Tiêu đề: POST /api/admin/import-products không rollback batch khi có dòng lỗi
 - Mức độ: High / Functional
 - Mô tả: README FR-16 yêu cầu all-or-nothing: nếu bất kỳ dòng nào lỗi, toàn bộ batch phải rollback. Thực tế các dòng valid vẫn bị commit vào DB khi batch có dòng invalid.
 - Bước tái hiện: admin JWT + batch [valid, invalid name="", valid] → kiểm tra DB sau request
 - Expected: không product nào của batch được lưu
 - Actual: product valid vẫn tồn tại trong DB (partial commit)
 - Evidence: FR16-ATOM-001 đến ATOM-004 trong canonical run
 - Root cause: server.js:209-231 dùng forEach + stmt.run không có db.run("BEGIN TRANSACTION") / db.run("ROLLBACK")
 - Nguồn: README FR-16

Format mỗi bug report giống bug-report/fr-11-idor-missing-auth.md. Mỗi report có: mã vấn đề, mức độ, mô tả, điều kiện tái hiện, bước tái hiện, expected vs actual, evidence, root cause, nguồn, tác động, trạng thái.

2. Cập nhật README.md thêm section FR-16 (Pool C):

- API: FR-16, POST /api/admin/import-products
- Test cases: 40 AI + 5 human = 45
- Audit: 29 VALID, 2 INVALID, 9 INCOMPLETE
- Executed: 32 ca, 77 assertions, 69 passed, 8 failed
- Bugs: 3 (missing role check, missing price validation, missing rollback)
- Postman features: giữ list đã có, bổ sung nếu dùng thêm feature mới

AI Output:

Đã tạo ba local bug report cho missing admin role check, missing price validation và missing atomicity/rollback. Mỗi report có mã vấn đề, severity, điều kiện/curl tái hiện, expected/actual, canonical evidence, source root cause, nguồn yêu cầu, tác động và trạng thái GitHub Issue NOT CREATED.

README đã được mở rộng cho Pool C / FR-16 với 45 designed cases, audit 29 VALID + 2 INVALID + 9 INCOMPLETE, execution 32 cases / 77 assertions / 69 passed / 8 failed và ba confirmed bugs. Danh sách Postman bổ sung pm.sendRequest cho post-condition persistence/rollback.

PHASE E: COMPLETE
GITHUB ISSUES: NOT CREATED
FR-16 CI/CD: NOT CREATED
AI CRITIQUE: NOT CREATED

Đánh giá/chỉnh sửa của con người:

PENDING

Entry #18

AI Audit Entry

Tool: Codex (GPT-5)

Date: 21/08/2026 20:41 – Asia/Ho_Chi_Minh

Purpose: PHASE A – scope selection and contract extraction for FR-05 / GET /api/products with optional search

User Prompt:

sử dụng ai-first-api-testing thực hiện:
\- Pool A
\- FR-05 – Product Listing and Search
\- Endpoint thuộc phạm vi:
 \- GET /api/products
 \- query tùy chọn: ?search=\<keyword>

Lần chạy FR-05 này dự kiến được dùng để phục vụ demo Agent Skill.

\## NGUYÊN TẮC PHẠM VI

Chỉ tập trung vào FR-05.

Không phân tích, mô tả, tạo test hoặc mở rộng sang:
\- product detail;
\- product CRUD;
\- category API;
\- authentication feature;
\- hoặc bất kỳ FR/endpoint nào khác.

Chỉ đọc rule khác nếu trực tiếp ảnh hưởng đến FR-05.

Không trình bày tổng quan Pool A.

\## TÀI LIỆU CẦN DÙNG

Đọc và tuân thủ:

- \- SKILL.md
- \- references/phase-playbook.md
- \- references/api-selection-contract.md
- \- references/api-testing-runbook.md
- \- references/assignment-requirements.md
- \- src/eshop-sut/api_specification.md
- \- src/eshop-sut/README.md

Chỉ đọc source code nếu cần kiểm tra spec gap trực tiếp của FR-05.

\## PHẠM VI THỰC THI

Chỉ thực hiện:

PHASE A – CHỌN PHẠM VI / TRÍCH XUẤT CONTRACT CHO FR-05

Không được:

- \- sinh >=35 test cases;
- \- audit;
- \- human extension;
- \- tạo executable tests;
- \- chạy Postman/Newman;
- \- bug reporting;
- \- CI/CD;
- \- final reporting;
- \- chuyển sang Phase B.

Sau Phase A phải DỪNG.

\## NHIỆM VỤ

1\. Xác minh scope:

- \- GET /api/products
- \- optional query ?search=<keyword>

2\. Trích xuất contract chỉ cho FR-05:

- \- method/path;
- \- auth requirement nếu có;
- \- search query;
- \- optional/required;
- \- search semantics có nguồn;
- \- response information có nguồn;
- \- schema information có nguồn;
- \- security concern trực tiếp;
- \- spec gaps;
- \- data dependency.

3\. Kiểm tra tài liệu có định nghĩa hay không đối với:

- \- partial/exact search;
- \- case sensitivity;
- \- whitespace;

- \- empty search;
- \- Unicode/Vietnamese;
- \- special characters;
- \- long keyword;
- \- numeric input;
- \- encoded input;
- \- no-match result;
- \- ordering.

Nếu không có rule thì ghi:

INCOMPLETE ORACLE / SPEC GAP

Không tự suy đoán expected behavior.

4\.. Xây dựng planned partitions cho Phase B:

- \- request không có search;
- \- valid existing keyword;
- \- nonexistent keyword;
- \- empty;
- \- whitespace;
- \- one-character keyword;
- \- long keyword;
- \- numeric keyword;
- \- special characters;
- \- Unicode/Vietnamese;
- \- encoded input;
- \- injection-oriented input nếu phù hợp.

5\.. Chỉ áp dụng security concern liên quan trực tiếp đến FR-05:

- \- injection qua search;
- \- information exposure;
- \- unsafe output nếu có sink phù hợp;
- \- authentication chỉ nếu contract yêu cầu.

Không mở rộng sang các endpoint khác.

6\.. Không tự bịa:

- \- pagination;
- \- sorting;
- \- filters khác;
- \- status code;
- \- response schema;
- \- search behavior.

7\.. Exact schema assertion chỉ được xem là complete nếu tài liệu có source rõ ràng.

Nếu không có exact schema thì ghi:

SCHEMA ORACLE: INCOMPLETE

8\.. Xác định Student ID nhưng không execute request.

9\ . Chỉ tạo/cập nhật artifact cho Phase A của FR-05.

10\ . Ghi AI Audit cho interaction này.

\## OUTPUT CUỐI

Chỉ báo cáo:

\### FR-05 Scope

\### Contract

\### Search Input Model

\### Applicable Security

\### Response / Schema Oracle

\### Spec Gaps

\### Data Dependencies

\### Artifact Paths

\### Demo Readiness Note

Chỉ nêu artifact của FR-05 giúp demo workflow để quan sát.
Không trình bày các FR khác.

\### Status

Dùng:

PHASE A: COMPLETE

HUMAN REVIEW: PENDING

NEXT ALLOWED PHASE: B – AI GENERATION

EXECUTION: NOT EXECUTED

Sau đó DỪNG.

Không được tự động chạy Phase B.

AI Output:

FR-05 Scope

Đã khóa phạm vi vào `GET /api/products` và query tùy chọn `?search=<keyword>`.
Student ID là `23127464`; mọi request ở phase thực thi sau này phải có `X-Student-Id: 23127464`. Không request nào được gửi.

Contract

Nguồn chỉ xác định `search` là tùy chọn, tìm theo tên sản phẩm; khi không có search, use case là danh sách tất cả sản phẩm. Không có JWT/admin requirement được tài liệu hóa cho GET này. Product detail, CRUD, category, authentication feature và mọi endpoint khác bị loại khỏi phạm vi.

Search Input Model

Artifact lập planned partitions cho: không có search, keyword tồn tại/không tồn tại, empty, whitespace, một ký tự, dài, numeric, special characters, Unicode/Vietnamese, encoded và injection-oriented. Đây không phải test cases. Mọi semantics chưa có nguồn được gắn `INCOMPLETE ORACLE / SPEC GAP`.

Applicable Security

Chỉ ánh xạ SEC-05/injection qua search, information exposure từ database error, và SEC-04 cho sink hiển thị keyword đã được README định nghĩa. Source hiện tại nội suy search vào SQL và có thể đưa `err.message` vào HTML error; đây là quan sát tĩnh, chưa phải bug runtime. Authentication không áp dụng theo contract FR-05.

Response / Schema Oracle

README chỉ cung cấp nhu cầu UI về image/name/price và empty state; không định nghĩa exact API status, envelope, fields/types hay empty-result representation. Các cột và `SELECT \*` trong source chỉ là implementation observation.

SCHEMA ORACLE: INCOMPLETE

Spec Gaps

Partial/exact, case sensitivity, whitespace, empty, Unicode/Vietnamese, special characters, long/numeric/encoded input, exact no-match API result và ordering đều là `INCOMPLETE ORACLE / SPEC GAP`. Không bịa pagination, sorting parameter, filter, status code, schema hay search behavior.

Data Dependencies

Phase B cần baseline sản phẩm có kiểm soát, tên tồn tại ổn định, keyword chắc chắn không tồn tại, dữ liệu Vietnamese nếu muốn assert match, và isolation khỏi dữ liệu CRUD/import trước đó. Seed source hiện có 5 product candidates nhưng không được coi là contract data.

Artifact Paths

- `reports/api-testing/fr-05-phase-a-contract.md`
- `reports/ai-audit-report.md` – Entry #18

Demo Readiness Note

Artifact thể hiện rõ scope lock, contract extraction theo nguồn, phân biệt contract với implementation, planned partitions không sinh test, security mapping có giới hạn và incomplete-oracle labels. Sẵn sàng cho demo điểm bàn giao Phase A; cần human review trước Phase B.

Status

PHASE A: COMPLETE
HUMAN REVIEW: PENDING
NEXT ALLOWED PHASE: B – AI GENERATION
EXECUTION: NOT EXECUTED

Đánh giá/chỉnh sửa của con người:

PENDING

Entry #19

AI Audit Entry

Tool: Codex (GPT-5)

Date: 21/08/2026 20:59 – Asia/Ho_Chi_Minh

Purpose: Phê duyệt Phase A và thực hiện Phase B – AI Generation cho FR-05 / GET /api/products

User Prompt:

approve, continue

AI Output:

Approval

Phase A của FR-05 đã được ghi nhận HUMAN REVIEW: APPROVED – 2026-08-21. Phạm vi tiếp tục bị khóa ở GET /api/products với query tùy chọn search; Student ID là 23127464.

Phase B Result

Đã sinh 40 test case AI với 40 ID duy nhất, không trùng. Không có human-added case, chưa thực hiện case-by-case audit, chưa tạo executable tests và không gửi HTTP request.

Coverage

Bao phủ listing, response information, keyword tồn tại/không tồn tại, empty, duplicate query, whitespace, một ký tự, keyword dài, numeric, ký tự đặc biệt, Unicode/tiếng Việt, encoded input, SQL injection, information exposure và unsafe output tại sink phù hợp.

Oracle Control

Không tự đặt status code, content type, exact schema, ordering hoặc search semantics. Partial/exact, case, whitespace, length, encoding và exact no-match representation tiếp tục được gán INCOMPLETE ORACLE / SPEC GAP.

Artifact Paths

- reports/api-testing/fr-05-phase-a-contract.md
- reports/api-testing/fr-05-phase-b-generation.md
- tests/api-testing/test-cases/fr-05-ai-generated-phase-b.md
- reports/ai-audit-report.md – Entry #19

Status

PHASE B: COMPLETE
AI-GENERATED TEST CASES: 40
HUMAN CASE-BY-CASE AUDIT: PENDING
NEXT ALLOWED PHASE: C – HUMAN REVIEW
EXECUTION: NOT EXECUTED

Đánh giá/chỉnh sửa của con người:

PENDING

Entry #20

AI Audit Entry

Tool: Codex (GPT-5)

Date: 21/08/2026 21:07 – Asia/Ho_Chi_Minh

Purpose: PHASE C – tạo Human Review Worksheet và AI pre-audit cho 40 ca FR-05 / GET /api/products

User Prompt:

Đọc và tuân thủ:

- ai-first-api-testing/SKILL.md
- ai-first-api-testing/references/phase-playbook.md
- ai-first-api-testing/references/api-testing-runbook.md
- reports/api-testing/fr-05-phase-a-contract.md
- tests/api-testing/test-cases/fr-05-ai-generated-phase-b.md

PHẠM VI

Pool A, FR-05, GET /api/products.
Student ID: 23127464.
Chỉ thực hiện PHASE C – HUMAN REVIEW WORKSHEET.
Không execute, không báo bug, không CI/CD.
Sau Phase C phải DỪNG.

NHIỆM VỤ

1. Tính SHA-256 của file tests/api-testing/test-cases/fr-05-ai-generated-phase-b.md
2. Tạo file tests/api-testing/test-cases/fr-05-phase-c-human-review-workbook.md:

Phần A: Bảng kiểm toán AI pre-audit cho 40 ca

| Mã | Mô tả rút gọn | Danh mục | Đề xuất AI | Lý do AI |
Kết luận con người | Lý do con người | Chỉnh sửa cuối cùng |

Quy tắc:

- VALID: input, bước, oracle đều có nguồn và thực thi được.
Lưu ý: FR-05 có rất nhiều SPEC GAP, nên ca có oracle bảo mật (không lộ SQL, không inject, không render HTML) vẫn có thể VALID vì oracle bảo mật có nguồn từ SEC-04/SEC-05.
Ca listing/existing keyword có oracle semantic (trả sản phẩm đúng) cũng VALID dù schema chưa có.
- INVALID: trùng lặp hoặc ngoài phạm vi.
- INCOMPLETE: có ý nghĩa nhưng thiếu oracle hoàn toàn – chỉ khám phá, không thể assert bất kỳ điều gì.

Cột "Kết luận con người", "Lý do con người", "Chỉnh sửa cuối cùng" để PENDING.

3. Thống kê: số VALID, INVALID, INCOMPLETE.

Phần B: 5 slot PENDING cho ca con người bổ sung

| Slot | Mã | Mục tiêu | Nguồn | Lý do AI bỏ sót | Xác nhận |

Phần C: Gate Phase C (checklist PENDING)

Trạng thái

PHASE C: IN PROGRESS
AI PRE-AUDIT: COMPLETE
HUMAN AUDIT: PENDING
HUMAN-ADDED: PENDING

4. Ghi AI Audit. Sau đó DỪNG.

AI Output:

SHA-256

File Phase B có SHA-256:

C9392ECB27D3AA60DEB4B673B9B61348A18884BD9ADB39D6E168C145A54FE324

Hash trong worksheet đã được đối chiếu và khớp với file nguồn.

Phase C Worksheet

Đã tạo worksheet đủ 40 dòng pre-audit cho FR-05. Mỗi dòng có đề xuất AI và lý do; cả ba cột Kết luận con người, Lý do con người, Chính sửa cuối cùng đều là PENDING.

AI Pre-audit Statistics

- VALID: 16
- INVALID: 2
- INCOMPLETE: 22
- Tổng: 40

Đây chỉ là đề xuất AI, chưa phải kết luận của con người.

Human Review State

Đã tạo đúng 5 slot human-added, tất cả PENDING. Toàn bộ Gate Phase C vẫn PENDING. Không tạo executable tests, không execute request, không báo bug và không tạo CI/CD.

Artifact Path

tests/api-testing/test-cases/fr-05-phase-c-human-review-workbook.md

Status

PHASE C: IN PROGRESS
AI PRE-AUDIT: COMPLETE
HUMAN AUDIT: PENDING
HUMAN-ADDED: PENDING
EXECUTION: NOT EXECUTED

Đánh giá/chỉnh sửa của con người:

PENDING

Entry #21

AI Audit Entry

Tool: **Codex** (GPT-5)

Date: 21/08/2026 21:34 — Asia/Ho_Chi_Minh

Purpose: Phê duyệt gate cuối Phase C và thực hiện Phase D — Execution cho FR-05 / GET /api/products

User Prompt:

approve, continue

AI Output:

Kết quả

Phase C đã được phê duyệt. Phase D đã tự động hóa và chạy 20 ca FR-05: 16 đạt, 4 không đạt; 50/55 assertion đạt. Lần chạy canonical là 20260821-213052.

Bốn ca không đạt là FR05-SEC-001, FR05-SEC-002, FR05-SEC-004 và FR05-H05; tất cả được phân loại LOI_BAO_MAT_SUT từ bằng chứng thực thi. Không tạo bug report và không chuyển sang Phase E.

Lần 20260821-213008 bị mất query string khi sinh collection được bảo toàn và phân loại LOI_CA_KIEM_THU, không dùng để kết luận SUT. Database đã được khôi phục đúng SHA-256 trước chạy. Ảnh Postman chứng minh header vẫn PENDING HUMAN CAPTURE.

Artifact Paths

- reports/api-testing/fr-05-phase-d-execution-plan.md
- reports/api-testing/fr-05-phase-d-execution-analysis.md
- tests/api-testing/collections/23127464_FR05_Product_Search.postman_collection.json
- tests/api-testing/environments/fr-05-local.postman_environment.json
- tests/api-testing/data/fr-05-run-data.json
- tests/api-testing/evidence/fr-05/20260821-213052/
- tests/api-testing/evidence/fr-05/20260821-213008/

Status

PHASE D: COMPLETE
EXECUTION: EXECUTED — FAILED
PASSED CASES: 16
FAILED CASES: 4
HUMAN ASSESSMENT: PENDING
HEADER SCREENSHOT: PENDING HUMAN CAPTURE
BUG REPORTING: NOT STARTED
PHASE E: NOT STARTED

Đánh giá/chỉnh sửa của con người:

PENDING

Entry #22

AI Audit Entry

Tool: Codex (GPT-5)

Date: 21/08/2026 22:00 – Asia/Ho_Chi_Minh

Purpose: PHASE E – tạo local security bug report và hoàn tất báo cáo FR-05 / GET /api/products

User Prompt:

Thực hiện Phase E cho FR-05. Đọc trước:

- reports/api-testing/fr-05-phase-d-execution-analysis.md
- tests/api-testing/test-cases/fr-05-phase-c-human-review-workbook.md
- reports/api-testing/fr-05-phase-a-contract.md
- src/eshop-sut/backend/server.js dòng 141-157

Tạo bug report bug-report/fr-05-sql-injection-search.md cho SQL injection qua search với bốn biểu hiện đã xác nhận; cập nhật README.md với thống kê FR-05; cập nhật AI Audit cho Phase A, B, C, D, E. Không tạo GitHub Issue.

AI Output:

Phase traceability

- Phase A: Entry #18 – contract extraction; COMPLETE và đã được con người phê duyệt.
- Phase B: Entry #19 – 40 AI-generated cases; COMPLETE.
- Phase C: Entry #20 – AI pre-audit/workbook; workbook cuối xác nhận 16 VALID, 2 INVALID, 22 INCOMPLETE và 5 human-added cases; COMPLETE.
- Phase D: Entry #21 – 20 ca được thực thi, 55 assertions, 50 passed, 5 failed; con người xác nhận 4 LOI_BAO_MAT_SUT; COMPLETE.
- Phase E: Entry #22 – một local bug report Critical / Security được tạo cho SQL injection với bốn biểu hiện; COMPLETE.

Phase E result

Đã tạo bug-report/fr-05-sql-injection-search.md theo format bug FR-11. Báo cáo gom bốn biểu hiện FR05-SEC-001, FR05-SEC-002, FR05-SEC-004 và FR05-H05 vào cùng root cause tại server.js:143-149; có curl với payload URL-encoded, expected/actual, evidence, source và remediation bằng parameterized query.

README.md đã có section FR-05 Pool A: 45 ca thiết kế, audit 16 VALID / 2 INVALID / 22 INCOMPLETE, thực thi 20 ca với 50/55 assertions đạt và một bug SQL injection có bốn biểu hiện.

Artifact Paths

- bug-report/fr-05-sql-injection-search.md
- README.md
- reports/api-testing/fr-05-phase-d-execution-analysis.md
- reports/ai-audit-report.md – Entry #22

Status

PHASE E: COMPLETE – LOCAL BUG REPORT CREATED
GITHUB ISSUE: NOT CREATED
CI/CD: NOT CREATED

Đánh giá/chỉnh sửa của con người:

PENDING